D3COY 1.0 | PS 01 | 14-HOUR WINNING PLAN

SENTINEL GRID

AI-Based National Cyber Threat Early Warning System

Product requirements and hackathon-winning roadmap

Core features | Technical requirements | Demo and visual design
14-hour build plan | Production-ready prototype checklist | Pitch and Q&A

Version 1.0 | 31 October 2026 | Build window: 14 hours, team of 4

A new threat appears. We match it to your assets, rank it, explain it, and get a human to approve the fix, before it becomes an incident.

1. Winning thesis

Most teams on PS 01 will ship the same thing: a dark dashboard that lists CVEs sorted by CVSS, plus an LLM-written summary. Judges will have seen it five times before lunch. SENTINEL GRID wins by being the one entry that is **correct, explainable, alive on stage and honest**.

THE ONE IDEA Intelligence only becomes a warning after it is matched to what you actually run. A critical CVE you do not run is information, not an alert. Every number shows its reason; every action needs a human; the demo never depends on the internet.

1.1 How judges score, and how we hit each criterion

Typical criterion	What judges look for	What we show	Proof moment
Problem fit (PS 01)	Aggregation, AI analysis, early warning, risk ranking, recommendations, dashboard	All six PS asks mapped on one slide; each visible in the demo	Traceability slide + live demo
Innovation	Something beyond a CVE list	Exposure-first gate, six exposure statuses, separate confidence, approval loop	Critical CVE with no asset match creates no alert
Technical depth	Real engineering, not an API wrapper	Version-range matcher, rule-based scorer with tests, state machine, guardrails	Score breakdown and rules-fired panel
Working demo	It runs, live, without drama	Offline seed, one-click inject, reset button, recorded backup	Inject advisory live in under 30 s
UX and visuals	Clarity at a glance	Mission-control UI, animated pipeline, score gauge, glowing exposure path	Band flips High to Critical on KEV listing
Responsible AI	Hallucination and safety thinking	ID verification, citation check, injection blocked, LLM optional	Fake CVE and hidden instruction caught live
Impact and scale	Who benefits, can it grow	Persona fit for SOC, patch manager, CISO; roadmap to Wazuh/SIEM/multi-tenant	One roadmap slide
Honesty	No hype	Weights labelled uncalibrated; back-test sample size stated	Metrics slide with caveats

1.2 How we bypass the typical competitor

Typical competitor move	Why it loses	Our counter
CVSS-sorted CVE table	Severity is not urgency; no link to the organisation	Exposure gate + five dimensions + confidence
LLM summary of an advisory	Hallucination risk; no evidence; fails when API is down	Deterministic brief is source of truth; LLM is optional and validated
Claims like 'predicts attacks with 95% accuracy'	Unverifiable; experienced judges distrust it	Say 'early warning and prioritisation'; show a labelled back-test with sample size
Live API calls in the demo	Rate limits and Wi-Fi kill the demo	Cached seed is the source of truth; live fetch is a bonus
Single static screen	No story, no interaction	Scripted 3-minute story: ingest, match, score, escalate, block, approve, close
No response workflow	Stops at an alert	14-status lifecycle with approval, verification, closure (simulated connectors, labelled)

2. Core product requirements

Scope is deliberately narrower than the full PRD. In 14 hours, **depth on one polished path beats breadth**. Priority: **P0** = demo fails without it; **P1** = wow multiplier, built only after P0 is green; **Cut** = not built, mentioned on the roadmap slide.

2.1 P0 features (must ship by hour 8)

ID	Feature	What it does	Acceptance test
F1	Cached intelligence ingestion	Loads NVD, CISA KEV, EPSS snapshots, 3-4 CERT-In/vendor advisories and one abuse.ch IOC file from local JSON/HTML. Stores raw payload, source URL, timestamps, content hash. Deduplicates echoes	Re-running ingest creates no duplicates; every item shows source and time
F2	Entity extraction	Regex for CVE IDs and IOCs (defanged), rule-based product and version-range parsing into structured constraints	30-item gold set: CVE IDs at least 0.95 precision
F3	Exploitation evidence ladder	L0 none, L1 EPSS band, L2 public PoC, L3 vendor says exploited, L4 corroborated by independent origins, L5 in CISA KEV. E value taken from the highest supported level	Each warning names its ladder level and evidence item
F4	Asset inventory and matcher	40-60 synthetic assets (CSV). Version-aware matcher with alias table and six statuses: CONFIRMED, LIKELY, POSSIBLE, MITIGATED, NOT_AFFECTED, UNKNOWN_GAP	Unit tests for range edges (before, through, between, unknown version, backport flag)
F5	Transparent scorer	Priority = 100 x (0.30 S + 0.30 E + 0.20 X + 0.10 V + 0.10 I) with gate and floor/cap rules and a separate confidence value	Worked example reproduces 82.0 (High); KEV listing gives 93.4 (Critical)
F6	Early warning object and brief	Structured warning with evidence list and citations. Deterministic template renders a 4-line brief. Recommendations from versioned playbooks	Works with the LLM switched off
F7	Guardrails	Every CVE/ATT&CK; ID verified against local data; feed text treated as untrusted data; uncited claims rejected	Fake ID blocked; hidden instruction flagged, not obeyed
F8	Lifecycle, approval, audit	State machine (NEW to CLOSED, 14 statuses), approver role, append-only audit log. Actions are simulated and labelled SIMULATED	Illegal transition rejected; every change in audit log
F9	Dashboard P0 screens	Overview, warning queue, warning detail, asset exposure	Judge reaches evidence in two clicks

2.2 P1 features (hours 8 to 11, in this order)

Order	Feature	Why it wins	Time box
1	Live inject-advisory button with animated pipeline (SSE)	The single most memorable demo moment	1.5 h
2	KEV escalation re-evaluation with animated score and band change	Shows early warning that reacts to new evidence	1 h
3	Glowing exposure path graph (CVE to product to asset)	Instantly shows blast radius	1.5 h
4	What-if patch simulation	Shows risk reduction as a number	45 min
5	LLM narrative with citation validation and template fallback	AI story with safety story attached	1 h
6	Back-test lead time versus KEV on a stated window	Measured, not claimed	45 min

2.3 Cut list (say 'roadmap', do not build)

- Real SIEM, EDR, firewall connectors; real automation; multi-tenant isolation; multilingual sources.
- Embedding clustering, fine-tuned models, Neo4j, Celery/Redis, Kubernetes.
- Live scraping of CERT-In; OTX, PhishTank, MalwareBazaar feeds; notifications beyond a simulated Slack-style card.

CUT LINE If behind schedule at hour 8, cut P1 items from the bottom of the list. Never cut: matcher, scorer with breakdown, citations, ID verification, approval gate, audit log, offline seed, reset button.

3. Technical requirements

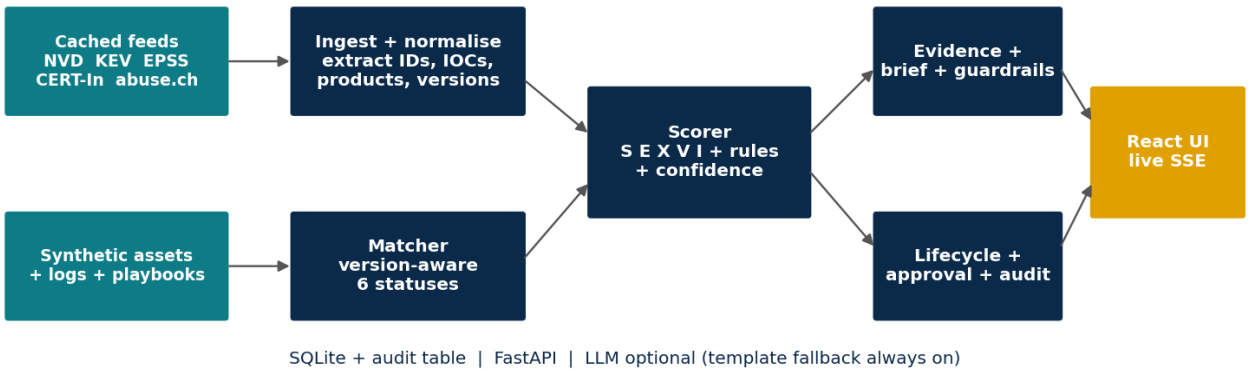


Figure 1. System architecture: deterministic core, optional AI layer, human-gated response loop

3.1 Stack (chosen for speed and demo safety)

Layer	Choice	Reason
Frontend	React + Vite + TypeScript + Tailwind, Framer Motion, Recharts, React Flow	Fast build, strong animation support, no SSR needed
Backend	Python 3.11, FastAPI, Pydantic, SQLAlchemy	Typed schemas, auto API docs, quick to write
Database	SQLite by default (zero setup, demo-safe); schema kept portable to PostgreSQL	One file, no service to crash on stage
Matching and text	packaging (version compare), rapidfuzz (alias matching), regex, scikit-learn TF-IDF (P1 only)	Deterministic and testable
Live updates	Server-Sent Events from FastAPI	Simpler than WebSockets; drives the animated pipeline
LLM	Provider-agnostic gateway (Gemini default); strict JSON output; template fallback always on	Demo survives API failure
Packaging	docker compose up, plus make demo for local; .env.example	One command to run on any judge's machine

3.2 Data model (minimum tables)

Table	Key fields
intel_item	id, source, url, published_at, collected_at, content_hash, origin_id, raw_json
threat	id, cve_ids, title, products, version_constraints, exploitation_level, epss, kev_flag, first_seen
asset	id, hostname, product, version, environment, internet_facing, criticality, owner, last_verified, synthetic=true
exposure	id, threat_id, asset_id, status, matched_range, alias_used, evidence
warning	id, threat_id, dimensions_json, confidence, band, rules_fired, status, created_at, updated_at
evidence_link	warning_id, intel_item_id, citation_key
audit_log (append-only)	id, ts, actor, action, object, before, after, reason, simulated
playbook	id, version, condition, steps

3.3 API surface

Endpoint	Purpose
GET /overview, /warnings, /warnings/{id}, /assets, /feed	Read models for the four main screens
POST /demo/inject/{scenario}	Injects a scripted advisory; streams pipeline events
POST /demo/kev/{cve}	Adds a CVE to the cached KEV list and triggers re-evaluation

Endpoint	Purpose
POST /warnings/{id}/transition	Lifecycle change with reason; enforces state machine and roles
POST /warnings/{id}/approve	Approver-only; runs simulated action and logs it
GET /events (SSE)	Live stage events: ingest, extract, match, score, warn
POST /demo/reset	Restores seed data in under 5 seconds
GET /health	Source status, DB, LLM on/off

3.4 Scoring specification

S = CVSS/10. E = highest ladder level (0.10, 0.2-0.6 by EPSS band, 0.65, 0.80, 0.90, 1.00). X = match strength x exposure factor (internet-facing, control adjustments). V = new independent origins in the last window, normalised. I = asset criticality and dependencies. **Confidence** (0 to 1) comes from source reliability, independent corroboration, freshness and match certainty, and is displayed beside priority, never hidden inside it.

Rule	Effect
R1 No eligible exposure	No warning; item stays in feed as information
R2 KEV + confirmed exposure + internet-facing	Band at least Critical
R3 KEV + confirmed or likely exposure	Band at least High
R4 Status POSSIBLE	Band at most Medium until verified
R5 Confidence below 0.40	Band at most Medium; labelled low confidence
R6 Non-production isolated asset	Band at most High
Bands	Critical 85 to 100, High 70 to 84, Medium 40 to 69, Low below 40

HONESTY Weights, ladder values and thresholds are expert-set starting values, not calibrated and not a standard. Say so on the scoring screen and on the slide. Judges reward honesty and punish false precision.

3.5 Guardrails (show these on stage)

- **ID verification:** every CVE and ATT&CK; ID in any output is checked against local NVD/ATT&CK; data before display.
- **Untrusted text:** feed content is escaped, never given tool authority, kept out of the system prompt; instruction-like strings are flagged.
- **Citation check:** narrative sentences without a valid evidence key are rejected and replaced by the template brief.
- **Privacy:** hostnames and IPs tokenised before any external LLM call; calls logged; LLM is opt-in.
- **Agent limits (if used):** read-only tools, step budget, full audit; no remediation by the model.

4. Hackathon optimisation: the 3-minute wow

4.1 Demo flow (rehearse until it is boring)

Time	What happens on screen	Line to say	Wow element
0:00-0:20	Overview: counters tick up, warnings by band, source health strip, synthetic-data badge	'Intelligence in, exposure-aware warnings out.'	Count-up numbers; cards slide in
0:20-0:55	Click Inject advisory. Animated pipeline lights up: Ingest, Extract, Match, Score, Warn. New card drops into queue	'From advisory to your asset in seconds.'	Pipeline stepper with live SSE events
0:55-1:35	Open warning: gauge counts up to 82.0 High; five dimension bars slide; rules fired; evidence with citations; exposure path glows from CVE to product to server	'Every number has a reason and a source.'	Gauge tween, bar growth, glowing graph path
1:35-1:55	Press Add to KEV. Gauge animates 82.0 to 93.4; band flips to Critical with a pulse; history line appears	'It reacts when the world changes.'	Number morph and band pulse
1:55-2:15	Open the poisoned report: hidden instruction and fake CVE. Shield badge flashes; fake ID blocked; deterministic brief shown	'AI helps, but is never trusted blindly.'	Guardrail shield animation
2:15-2:40	Approver approves simulated patch task; status moves through to VERIFICATION and CLOSED with snapshot	'Humans approve. The loop is closed.'	Status timeline fills
2:40-3:00	Show a critical CVE with no asset match: card dims, 'No warning: you do not run this'. Show metrics slide	'Fewer, better alerts.'	Fade-out of non-relevant card

4.2 Visual and animation spec

Element	Specification	Library / note
Theme	Mission-control dark UI; navy base, teal accent, amber for attention; bands use colour **plus** label and icon	Tailwind tokens; contrast checked for a projector
Pipeline stepper	Five nodes light in sequence as SSE events arrive; each shows a one-line result	Framer Motion; 400 ms per step
Risk gauge	Semi-circle gauge counting to value; colour by band; band label pulses on change	SVG + Framer Motion spring
Dimension bars	S, E, X, V, I bars grow in staggered; hover shows the formula part and evidence	Recharts or plain SVG
Exposure graph	CVE to product to asset nodes; active path glows; non-relevant nodes dim	React Flow; max 15 nodes
Live feed	New items slide in; unmatched items show a muted 'information only' tag	AnimatePresence
Status timeline	Horizontal stepper for lifecycle; current status highlighted	Simple CSS
Empty and error states	Designed, never blank; source outage shows degraded badge, not a crash	Required
Motion rules	Under 600 ms; no looping decoration; respect reduced-motion setting	Accessibility and taste

4.3 Intuitive user flow

- **Three-click rule:** Queue to Warning to Evidence. No menus a judge has to hunt for.
- **One primary button per screen:** Acknowledge, Inject, Approve. Secondary actions are quiet.
- **Guided demo mode:** a small 'Demo' panel (keyboard shortcuts 1 to 7) triggers scenarios so the presenter never fumbles.
- **Plain wording:** 'possible exposure' until confirmed; 'SIMULATED' on every mock action; 'SYNTHETIC' on inventory.

4.4 Make it work flawlessly on the day

Risk	Control
Wi-Fi or API failure	Full offline profile; LLM off by default; cached seed is truth
State drift between rehearsals	POST /demo/reset restores the seed in under 5 s; deterministic IDs and timestamps
Laptop or display issue	Run from a second machine; 1080p and 720p layouts tested; recorded backup video
Presenter nerves	Keyboard shortcuts for scenarios; script on a card; five full run-throughs
A bug in a P1 feature	Feature flags; P1 off by default in the final build unless it passed all rehearsals
Unexpected judge question	Prepared Q&A (section 7); an honest 'not in scope, here is the roadmap' is acceptable

5. 14-hour roadmap

Team of four with fixed ownership. If the team is smaller, merge Backend with Matching/AI and drop P1 items 3 to 6 first.

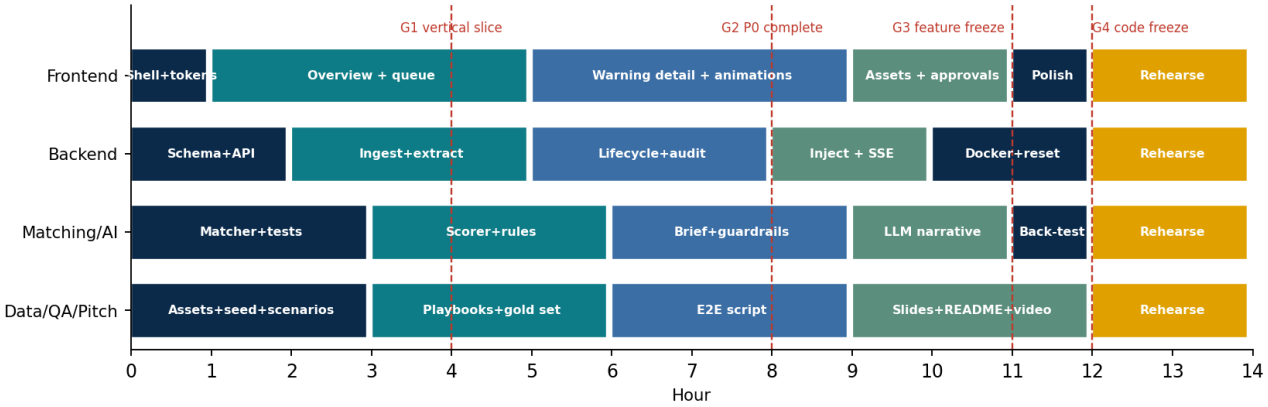


Figure 2. Parallel workstreams and decision gates (red dashed lines)

5.1 Hour-by-hour

Hours	Frontend/UX	Backend/Ingestion	Matching/AI	Data/QA/Pitch
0-1	Vite app, tokens, layout shell	Repo, FastAPI skeleton, DB models	Define status and rule enums	Agree scope; set up repo, board, naming
1-3	Overview and queue with mock data	Schema, seed loader, reset endpoint	Version parser, matcher core, alias table	Build 40-60 asset CSV; collect cached NVD/KEV/EPSS slice
3-4	Wire queue to API	Ingest NVD/KEV/EPSS from cache	Matcher tests green	Write 7 scenario advisories (placeholder CVEs)
H4 GATE 1	**Vertical slice:** one hard-coded advisory travels to a scored card in the UI. If not, stop and fix before anything else			
4-6	Warning detail skeleton, bars	CERT-In cached parse, abuse.ch load, extraction	Scorer, ladder, rules R1-R6, tests	Playbooks (8), gold set of 30 advisories
6-8	Gauge, evidence panel, asset view	Lifecycle state machine, roles, audit	Brief renderer, citation keys, ID verification	E2E script for scenarios 1-7; start README
H8 GATE 2	**P0 complete:** all P0 acceptance tests pass. Else cut P1 to the top two items			
8-10	Pipeline stepper, KEV animation	Inject endpoint, SSE events, KEV re-evaluation	Injection handling, fake-ID demo; start LLM gateway	Slides skeleton; metrics from back-test data
10-11	Exposure graph, approvals screen	Docker compose, health, reset hardening	LLM narrative with fallback; what-if	Test on second laptop; record backup video
H11 GATE 3	**Feature freeze.** No new features; bugs and polish only			
11-12	Polish, empty states, projector contrast	Error handling, logging	Back-test number, final unit tests	Finalise slides and README
H12 GATE 4	**Code freeze.** Tag release; build from clean checkout; run full scenario script			
12-14	Rehearse x5, timing, shortcuts	Standby for fixes (hotfix branch only)	Prepare technical Q&A	Run Q&A drill; pack backup video, slides, offline build

5.2 Working rules

- Interfaces first: agree JSON shapes for warning, asset and event in hour 1; Frontend mocks until the API is ready.
- Vertical slice before breadth; commit at least hourly; one integration branch; no long-lived feature branches.
- Unit tests for matcher, scorer and state machine are written alongside the code, not after.

- Every 3 hours: five-minute sync on gates and blockers. Decide, do not debate.

6. Production-ready prototype checklist

'Production-ready prototype' means it looks and behaves like a product a team could pilot: reproducible, tested, secure by default and honest about its limits. It does not mean production deployment.

Area	Requirement	Done when
Reproducibility	Single command start; pinned dependencies; .env.example; deterministic seed	Clean clone runs in under 5 minutes
Correctness	Automated tests for matcher (range edges), scorer (worked examples), state machine (legal and illegal moves), extraction (gold set)	Around 30-40 focused tests pass; run via one command
Security	No secrets in repo; input validation (Pydantic); output escaping in UI; role checks on approve and transition; CORS limited	Checklist reviewed at H11
Privacy	Synthetic data only; tokenise before external LLM; log what leaves the system	Visible in audit view
Resilience	Per-source failure isolation; timeouts and retries; graceful degraded state; reset endpoint	Kill any source: UI stays up
Observability	Structured logs; /health; audit log; pipeline events visible in UI	Presenter can show 'what happened' for any warning
Explainability	Every score reproducible from stored inputs and ruleset version; rules fired shown	Recompute equals displayed score
Performance	Ingest-to-warning under 30 s from cache; page load under 2 s on seed	Timed during rehearsal
Accessibility	Colour never the only signal; keyboard-reachable actions; readable at projector distance	Quick manual check
Compliance and licences	Source terms and attribution respected; datasets labelled synthetic or public; no scanning of real systems	Sources slide in README
Documentation	README (run, architecture, scoring, limits), scenario script, API docs from FastAPI, known limitations	Judge can follow without you
Honest limits	States: not calibrated, not predictive, simulated actions, synthetic inventory	On slides and in UI footer

7. Pitch, metrics and Q&A

7.1 Five-slide deck (supports the live demo, does not replace it)

#	Slide	Content
1	The problem	Fragmented intel, relevance gap, severity is not urgency, alert fatigue. One striking number or example
2	The idea	Exposure-first early warning in one diagram; six PS requirements ticked
3	How it works	Pipeline, scoring dimensions, guardrails, approval loop (Figure 1 style)
4	Proof	Metrics with caveats: extraction accuracy, test pass rate, latency, back-test lead time (window and sample size stated)
5	Roadmap and impact	Pilot with Wazuh/CMDB inventory, SIEM connectors, calibration with labels, national multi-tenant view

7.2 Metrics to report (only what you actually measured)

- Extraction precision and recall on the hand-labelled gold set (state its size).
- Matcher test pass rate and number of edge cases covered.
- Hallucination catch rate on injected invalid IDs; injection cases blocked.
- Ingest-to-warning latency from cache; warnings per day on seed; zero duplicates.
- Back-test: median and range of days between first system flag and KEV listing, with window and sample size. Present as indication, not proof.

7.3 Likely judge questions

Question	Strong answer
Is this not just CVSS plus EPSS plus KEV?	Those feed one dimension (E and S). The value is the exposure gate, version-aware matching, velocity, confidence and the approval loop. Show the no-match case.
How accurate is the score?	Weights are expert-set and uncalibrated; we say so. The plan is calibration from analyst accept/reject labels with time-split validation. Today we show reproducibility and the back-test indication.
Does AI do the scoring?	No. Scoring, matching and facts are deterministic. AI only drafts text from retrieved evidence, validated by citation and ID checks, with a template fallback.
What if the LLM or API fails?	Demo runs fully offline; deterministic brief is default.
What about prompt injection?	Feed text is untrusted data, never instructions; we demo a poisoned report being flagged.
How does this differ from MISP, OpenCTI, Wazuh?	They are complements: MISP and OpenCTI share and store intelligence; Wazuh supplies inventory. We add asset-first exposure scoring and a lightweight approval loop, and can ingest from or feed them.
Is the data real?	Threat data is public (NVD, KEV, EPSS, advisories). The inventory and logs are synthetic and labelled.
How would it scale nationally?	Shared global intelligence layer, tenant-private asset layer, row-level isolation, queue-based workers. Out of scope for the prototype.
Can it act automatically?	Not in the prototype. Actions need approval and are simulated. Future automation limited to pre-authorised, non-disruptive actions.

7.4 Final readiness checklist (hour 12 to 13)

Check	Pass
Clean-checkout build and run on a second laptop, offline	[ ]
All 7 scenarios run end to end from the demo panel in under 3 minutes	[ ]
Reset restores seed; second full run identical	[ ]
LLM off and LLM on both rehearsed; fallback tested	[ ]
Backup video recorded; slides and README exported to PDF	[ ]
Every claim on slides traceable to something we built or measured	[ ]
Team knows who answers which question	[ ]

FINAL RULE Judges forgive missing features but not a broken demo or an inflated claim. Protect the three-minute story above everything else.